

Administración y seguridad de claves de API

Autor: Leonid Yankulin **Última actualización:** 22 jun 2026

Fuente: <https://codelabs.developers.google.com/api-key-management?hl=es-419#0>

Contenido del Manual

1. Introducción
2. Configuración
3. Cómo restringir una clave de API nueva
4. Cómo catalogar tus claves de API
5. Descubre el uso de una clave de API
6. Define la detección de uso anómalo
7. Limpia
8. Resumen

1. Introducción

Históricamente, las claves de API de Google se usaban para acceder a las APIs de Google cuando otros métodos no estaban disponibles o se consideraban inconvenientes. Los casos de uso populares fueron el acceso a la API de Google Maps y a las APIs de Google expuestas por Firebase. Con la introducción de modelos de IA, agentes de IA como Gemini, y marcos de desarrollo de AI Studio y de agentes como el Kit de desarrollo de agentes, las claves de API se convirtieron en el método principal para acceder a los modelos de lenguaje grandes de Google.

Las claves de API ofrecen un nivel de protección bajo. Si bien Google Cloud proporciona varios métodos para evitar el uso inadecuado de las claves, tener una clave de API activa permite el acceso a las APIs de Google sin validaciones adicionales de autenticación o autorización. Los métodos para restringir el uso de las claves de API se describen en la [documentación](#). La entrada del blog de Cloud [Securing Your Gemini and Google API](#) keys brinda recomendaciones adicionales sobre el mantenimiento de las claves de API. En este codelab, pondrás en práctica estas recomendaciones.

i Nota: Si no usas claves de API, no podrás recibir resultados válidos cuando ejecutes los pasos de este codelab.

Actividades

- Revisa las restricciones aplicadas cuando crees claves de API nuevas en Google Cloud
- Cataloga todas tus claves de API y encuentra las que no tienen protección de seguridad.
- Aplicar restricciones a las claves de API existentes según su uso
- Define la automatización que borra la llave en caso de uso anormal

Requisitos

- Un navegador web moderno (como Chrome)
- Una Cuenta de Google

2. Configuración

En las instrucciones de este Codelab, se supone que ejecutas comandos en Cloud Shell en la consola de Google Cloud. Si tienes la [gcloud CLI](#) en tu entorno local, puedes ejecutar los comandos allí.

Si bien las operaciones de los pasos se pueden realizar con la IU de la consola de Cloud, los métodos son diferentes. En este codelab, se usa la interfaz de línea de comandos para simplificar las interacciones y permitir una integración más sencilla con los agentes de IA modernos (como la CLI de Antigravity).

Inicia una terminal de Cloud Shell

1. Abre la consola de Google Cloud en <https://console.cloud.google.com/> en una nueva ventana del navegador. Se recomienda usar Chrome para obtener la mejor experiencia del usuario.
2. Accede a tu Cuenta de Google en Google Cloud.
3. Haz clic en **Activar Cloud Shell**



en la parte superior de la consola de Google Cloud.

Si se muestra, haz clic en las siguientes ventanas:

- Continúa en la ventana de información de Cloud Shell.
- Autoriza a Cloud Shell para que use tus credenciales para realizar llamadas a la API de Google Cloud.

Selecciona un proyecto de Google Cloud

Después de abrir la consola de Cloud, se te autenticará y, por lo general, habrá una selección de proyectos para tu trabajo. El ID del proyecto es una secuencia de entre 6 y 30 caracteres que incluye letras en minúscula, números y guiones, por ejemplo, `qwiklabs-gcp-04-3075fc9fd77f`. La terminal de Cloud Shell configura la CLI de `gcloud` con el proyecto seleccionado. Verás un resultado similar al siguiente:

```
Your Cloud Platform project in this session is set to quiklabs-gcp-04-3075fc9fd77f
```

Esto significa que los próximos comandos que envíes a `gcloud` usarán el ID del proyecto `qwiklabs-gcp-04-3075fc9fd77f`.

Establece el ID del proyecto como una variable de entorno `PROJECT_ID`. Puedes ver la lista de todos tus proyectos con el siguiente comando:

```
gcloud projects list
```

- Reemplaza `your-project-id` y ejecuta el comando si deseas usar un ID de proyecto diferente del configurado en `gcloud`.

```
export PROJECT_ID="your-project-id"
```

Por ejemplo:

```
export PROJECT_ID="qwiklabs-gcp-04-3075fc9fd77f"
```

- Ejecuta el siguiente comando si deseas usar el ID del proyecto seleccionado:

```
export PROJECT_ID=$(gcloud config get project)
```

3. Cómo restringir una clave de API nueva

Anteriormente, los usuarios podían crear claves de API sin restricciones. Las claves sin restricciones se pueden usar para llamar a *CUALQUIER* API de Google habilitada en el proyecto en el que se creó la clave. Si bien la consola de Google Cloud impide que los usuarios creen claves sin restricciones, aún es posible hacerlo con la CLI de `gcloud` o con llamadas directas a la API.

En los siguientes pasos, se muestra cómo crear una clave de API restringida que limite el uso a la API específica y al sitio web especificado.

1. Para crear una clave de API nueva restringida al uso con la API de Google Maps Geolocation, ejecuta el siguiente comando en la terminal de shell:

```
gcloud services api-keys create --key-id=restricted-api-key \
  --display-name="restricted api key" \
  --api-target=service=geolocation.googleapis.com \
  --project=${PROJECT_ID}
```

Este comando crea una nueva clave de API que se puede usar *SOLO* para llamar al servicio de geolocalización de Google Maps.

i Nota: Es posible agregar varias APIs a la lista restringida. Usa varios parámetros `--api-target` con un valor `=service=SERVICE.googleapis.com`, donde `SERVICE` es uno de los servicios de Google.

2. Aumenta la seguridad de la clave agregando una restricción de la aplicación. Limita el uso de la clave a todas las rutas de acceso dentro del sitio web `example.com` únicamente. Ejecuta el siguiente comando para agregar la restricción de la aplicación a la clave:

```
gcloud services api-keys update restricted-api-key \
  --location=global \
  --allowed-referrers="example.com/*" \
  --project=${PROJECT_ID}
```

En lugar de permitir el uso de la clave en sitios web específicos, puedes usar `--allowed-application` para definir aplicaciones para Android permitidas o `allowed-ips` para definir direcciones IP permitidas. Consulta la [documentación](#) completa para ver todas las opciones.

i Nota: Es posible agregar más de una restricción de aplicación del mismo tipo (*SAME*) proporcionando varios parámetros (p.ej., `--allowed-referrers`). Si agregas varios tipos de restricciones de aplicación, solo se guardará el tipo más reciente en la lista de parámetros.

Limpia

Borra la clave de API que creaste, a menos que planees usarla:

```
gcloud services api-keys delete --key-id=restricted-api-key \
  --project=${PROJECT_ID}
```

4. Cómo catalogar tus claves de API

En este paso, usarás la CLI de `gcloud` para obtener un inventario de tus claves de API. En la lista resultante, se muestran todas las claves de API *activas* (no borradas) a las que tienes acceso.

⚠ Precaución: Solo puedes encontrar claves en los proyectos de Google Cloud a los que tienes acceso. Si creaste una clave de API (p.ej., una clave de Google Maps) con una interfaz que administró el proyecto en tu nombre, sin otorgarte derechos de acceso, no podrías ver las claves en ese proyecto con la CLI de `gcloud`.

1. Ejecuta el siguiente comando para ver todos los nombres, IDs y fechas de creación de las claves:

```
gcloud services api-keys list --project=${PROJECT_ID} \
  --format='value(displayName,name.basename(),createTime.date())'
```

El resultado mostrará el nombre legible por humanos de la clave, el ID de la clave y la fecha en que se creó. Se vería similar a lo siguiente:

api key 1	api-key-1	2024-05-10T07:53:24
api key 2	api-key-2	2025-06-12T14:47:57

2. Elige uno de los IDs de clave y pega el siguiente comando para verificar si la clave tiene alguna restricción. Sustituye `your-key-id` por el valor del ID de clave seleccionado:

```
gcloud services api-keys describe "your-key-id" --project=${PROJECT_ID}
```

El resultado (en YAML) contendrá una lista de restricciones en `restrictions`.

```
createTime: '2024-05-10T07:53:24.986528Z'
displayName: api key 1
etag: W/"u1WuY41K2tPKUZd7cfLoKg=="
name: projects/123456789012/locations/global/keys/api-key-1
restrictions:
  apiTargets:
    - service: geolocation.googleapis.com
  browserKeyRestrictions:
    allowedReferrers:
      - https://example.com/*
uid: 1a2b3c4d-1234-abcd-1234-a1b2c3d4e5f6
updateTime: '2024-05-10T07:53:24.071228Z'
```

Ten en cuenta que, si la clave nunca se actualizó, los campos `createTime` y `updateTime` tendrán la misma marca de tiempo.

!! Atención: Si el resultado no tiene el campo `restrictions`, esta clave de API **NO ESTÁ RESTRINGIDA**.

1. Descarga y ejecuta la secuencia de comandos que recorre *todos tus proyectos* y muestra todas las claves de API que **NO tienen restricciones**:

```
curl -fsSL -o unrestricted_api_keys.sh \  
  "https://github.com/GoogleCloudPlatform/devrel-demos/blob/main/security/api-key-  
-audit/unrestricted_api_keys.sh"  
chmod +x unrestricted_api_keys.sh  
./unrestricted_api_keys.sh
```

Después de ejecutar la secuencia de comandos, verás un resultado como el siguiente:

DISPLAY NAME	KEY ID	PROJECT ID	CREATION DATE
Key 1	1a2b3c4d-1234-abcd-1234-a1b2c3d4e5f6	my-project-1	2024-05-10T07:53:24.071228Z

Puedes encontrar todas las secuencias de comandos que se usan en este codelab en la [carpeta Security](#) del repositorio devrel-demos en GitHub.

5. Descubre el uso de una clave de API

En este paso, consultarás las métricas de Google Cloud que te ayudarán a encontrar qué APIs se llamaron con tu clave de API. Con esta información, puedes revisar el uso actual de las claves y aplicar restricciones de la API en la clave según la información real en lugar de hacer una suposición.

⚠ Precaución: Este paso requiere claves de API que ya se hayan usado durante un tiempo. Si no tienes esa clave, puedes revisar las instrucciones del paso para conocer los métodos de inspección del consumo de claves de API.

1. Usa el mismo ID de clave que usaste en el paso anterior o elige otro. Sustituye `your-key-id` por el ID de clave elegido en el siguiente comando:

```
export KEY_UID=$(  
  gcloud services api-keys describe "your-key-id" \  
  --format='value(uid)' \  
  --project=${PROJECT_ID})
```

2. Configura la búsqueda para que muestre el historial de uso de un año. Si deseas buscar un período más largo o más corto, reemplaza `365` (cantidad de días) por otro número positivo.

```
export DAYS=365
```

3. Actualiza las credenciales predeterminadas de la aplicación ([ADC](#)) para habilitar la llamada directa a la API de Cloud Monitoring. Ejecuta el siguiente comando y sigue las instrucciones en la terminal:

```
gcloud auth application-default login
```

4. Ejecuta el siguiente comando para enviar una solicitud de datos de métricas de uso del servicio a la API de Cloud Monitoring:

```
curl -s -G -H "Authorization: Bearer $(gcloud auth application-default print-access-token)" \
  --data-urlencode "filter=metric.type=\"serviceruntime.googleapis.com/api/request_count\" AND resource.labels.credential_id=\"apikey:${KEY_UID}\"" \
  --data-urlencode "interval.startTime=$(date -u -d "${DAYS} days ago" +%Y-%m-%dT%H:%M:%SZ)" \
  --data-urlencode "interval.endTime=$(date -u +%Y-%m-%dT%H:%M:%SZ)" \
  "https://monitoring.googleapis.com/v3/projects/${PROJECT_ID}/timeSeries" \
  | jq -r '.timeSeries[]?.resource.labels.service' | sort -u
```

El comando consulta la métrica integrada [serviceruntime/api/request_count](#) para obtener puntos de datos con la etiqueta `credential_id` que coinciden con el ID único de la clave de API elegida. Luego, recupera los valores de la etiqueta `service` y los imprime, a la vez que elimina las repeticiones.

Protección de la clave de API

En este paso, usarás la información recopilada en los pasos anteriores para actualizar la configuración de restricción de la clave de API según la información de uso.

Usarás la misma clave de API que se usó en el paso anterior. Si es necesario, vuelve a ejecutar las instrucciones de los pasos anteriores para asegurarte de que las variables de entorno `PROJECT_ID`, `KEY_UID` y `DAYS` estén configuradas.

1. Ejecuta el siguiente comando para recuperar la lista de APIs de Google a las que se llamó con la clave de API:

```
SERVICES=$(curl -s -G -H "Authorization: Bearer $(gcloud auth application-default print-access-token)"
--data-urlencode "filter=metric.type=\"serviceruntime.googleapis.com/api/request_count" AND
resource.labels.credential_id=\"apikey:${KEY_UID}\""
--data-urlencode "interval.startTime=$(date -u -d "${DAYS} days ago" +%Y-%m-%dT%H:%M:%SZ)"
--data-urlencode "interval.endTime=$(date -u +%Y-%m-%dT%H:%M:%SZ)"
```

```
"https://monitoring.googleapis.com/v3/projects/${PROJECT_ID}/timeSeries"
| jq -r '.timeSeries[]?.resource.labels.service' | sort -u)
```

1. Build the list of arguments to restrict the API usage for the API key based on the retrieved list.

```
```shell
API_TARGET_ARGS=()
for SERVICE in $SERVICES; do
 API_TARGET_ARGS+=("--api-target=service=${SERVICE}")
done
```

1. Reemplaza la lista de APIs restringidas por la lista no vacía:

```
if [${#API_TARGET_ARGS[@]} -gt 0]; then
 gcloud services api-keys update "projects/${PROJECT_ID}/locations/global/keys/${KEY_UID}" \
 ${API_TARGET_ARGS}
fi
```

## 6. Define la detección de uso anómalo

En los pasos anteriores, se mostró cómo explorar y proteger las claves de API. En este paso, se muestra cómo automatizar una respuesta a un aumento inesperado en el uso de la clave con la ayuda de las [Alertas de supervisión](#).

**i Nota:** El consumo anormal de la clave no necesariamente prueba que la clave esté comprometida. Esto puede deberse a un aumento inesperado de las operaciones válidas. Sigue las instrucciones de este paso para personalizar las condiciones de la alerta y la respuesta a la alerta.

En las siguientes instrucciones, se crea una alerta que se activa cuando la tasa de llamadas a la API que usan una clave de API aumenta en más del 10% en los últimos 5 minutos. La alerta está configurada para activar una secuencia de comandos de Cloud Build que borra la clave de API para evitar que se siga usando. La clave se puede restablecer durante los próximos 30 días. Consulta la [documentación](#) para obtener información sobre cómo recuperar la clave.

**!! Atención:** El flujo de trabajo no es atómico. Desde el momento en que se detecta el uso anómalo hasta que la secuencia de comandos de Cloud Build borra la clave, pueden pasar varios minutos.

Las instrucciones reutilizan las variables `PROJECT_ID` y `KEY_UID` que usaste en los pasos anteriores. Si deseas seleccionar otra clave o proyecto, establece los valores nuevos para estas variables como se describe en los pasos de Configuración y descubrimiento del uso de una clave de API.

1. Ejecuta la siguiente secuencia de comandos para crear un archivo de política de alertas:

```
cat <<EOF > alert_policy.json
{
 "displayName": "Credential API Request Count Increase Alert (Project: ${PROJECT_ID})",
 "combiner": "OR",
 "conditions": [
 {
 "displayName": "API Request Count Increase > 10% in 5m with Min Volume",
 "conditionPrometheusQueryLanguage": {
 "query": "(sum(increase(serviceruntime_googleapis_com:api_request_count{metric_label_credential_id=\"\"apikey:${KEY_UID}\"}[5m])) / (sum(increase(serviceruntime_googleapis_com:api_request_count{metric_label_credential_id=\"\"apikey:${KEY_UID}\"}[5m] offset 5m)) or on() vector(1)) > 1.10) and (sum(increase(serviceruntime_googleapis_com:api_request_count{metric_label_credential_id=\"\"apikey:${KEY_UID}\"}[5m])) > 50)",
 "duration": "0s",
 "evaluationInterval": "60s"
 }
 }
],
 "enabled": true
}
EOF
```

La política de alertas usa el siguiente filtro de PromQL para activar la alerta:

```
(sum(
 increase(
 serviceruntime_googleapis_com:api_request_count{metric_label_credential_id="API_KEY_UID"}[5m]
) /
 (sum(
 increase(
 serviceruntime_googleapis_com:api_request_count{metric_label_credential_id="API_KEY_UID"}[5m] offset 5m)
) or on() vector(1)) > 1.10)
and
(sum(
 increase(
 serviceruntime_googleapis_com:api_request_count{metric_label_credential_id=\"YOUR_CREDENTIAL_ID_HERE\"}[5m])) > 50)
```

Calcula la tasa de aumento y la compara con un período anterior. Y activa la alerta solo si es más de

un 10% mayor. Para evitar que se active la alerta cuando la cantidad total de llamadas sea insignificante, se condiciona la activación a que haya más de 50 llamadas a la API en el período. Para evitar el cálculo de `NaN` (división por cero) cuando la tasa de 5 minutos *anterior* era 0, se sustituye el denominador por 1 si la tasa del período anterior es cero. Puedes cambiar los parámetros de alerta, como la duración del período ( `5m` ), el umbral mínimo ( `50` ) o el umbral de aumento del 10% ( `1.10` ). Los parámetros de política adicionales definen que, una vez que se alcanza la condición, se debe activar la alerta ( `duration` ) y que la condición se debe sondear cada 60 segundos ( `evaluationInterval` ).

2. Ejecuta el siguiente comando para crear un tema de Pub/Sub que se usará para publicar notificaciones de alertas:

```
gcloud pubsub topics create api-key-alert-notifications --project=$PROJECT_ID
```

3. Ejecuta el siguiente comando para crear canales de notificaciones para alertas que usen Pub/Sub.

```
CHANNEL_NAME=$(gcloud beta monitoring channels create \
 --display-name="Pub/Sub Alert Channel" \
 --type="pubsub" \
 --channel-labels="topic=projects/$PROJECT_ID/topics/api-key-alert-notifications" \
 --format='value(name)' \
 --project=$PROJECT_ID)
```

Usarás la variable de entorno `CHANNEL_NAME` en el paso de limpieza.

4. Ejecuta el siguiente comando para crear una alerta de supervisión nueva:

```
gcloud monitoring policies create --policy-from-file=alert_policy.json \
 --project=$PROJECT_ID
```

5. Ejecuta el siguiente comando para otorgar permisos al servicio de Cloud Build para borrar las claves de API en el proyecto.

```
PROJECT_NUMBER=$(gcloud projects describe $PROJECT_ID --format="value(projectNumber)")
gcloud projects add-iam-policy-binding $PROJECT_ID \
 --member="serviceAccount:${PROJECT_NUMBER}@cloudbuild.gserviceaccount.com" \
 --role="roles/apikeys.admin"
```

Es posible limitar el rol de `apikeys.admin` para que solo manipule instancias específicas de las claves de API. Consulta [Condiciones de IAM](#) para obtener más detalles.

6. Ejecuta la siguiente secuencia de comandos para crear un activador de compilación de Cloud Build que borre la clave de API.

```
cat <<EOF > trigger_config.yaml
name: "delete-compromised-api-key"
description: "Triggered by Pub/Sub alert to automatically delete the leaking API
Key"
pubsubConfig:
 topic: "projects/${PROJECT_ID}/topics/api-key-alert-notifications"
build:
 steps:
 - name: "gcr.io/google.com/cloudsdktool/cloud-sdk:slim"
 args:
 - "gcloud"
 - "services"
 - "api-keys"
 - "delete"
 - "${KEY_UID}"
 - "--quiet"
EOF
```

7. Ejecuta el siguiente comando para crear un nuevo activador de alerta de supervisión:

```
gcloud builds triggers create pubsub \
 --trigger-config=trigger_config.yaml \
 --project=$PROJECT_ID
```

Ahora puedes borrar los archivos de configuración de la política de alertas y del activador de compilación de Cloud Build:

```
rm alert_policy.json trigger_config.yaml
```

Como alternativa, puedes configurar esta automatización con el plan de Terraform. Descarga los archivos de Terraform de la carpeta [abnormal-usage-detection](#) en el [repositorio](#) de DevRel de Google Cloud. El plan acepta un ID de proyecto y un UID de clave de API como parámetros de entrada, y configura los recursos y las configuraciones que viste en este paso.

## 7. Limpia

Para evitar que se apliquen cargos inesperados a tu cuenta de Google Cloud, recuerda borrar el tema de Pub/Sub, el activador de compilación de Cloud Build y las políticas de alertas que creaste durante este ejercicio.

Ejecuta los siguientes comandos para borrar todos los recursos que creaste:

```
gcloud builds triggers delete delete-compromised-api-key \
 --project=$PROJECT_ID
gcloud beta monitoring channels delete $CHANNEL_NAME \
 --project=$PROJECT_ID \
 --quiet
gcloud pubsub topics delete api-key-alert-notifications \
 --project=$PROJECT_ID
gcloud projects remove-iam-policy-binding $PROJECT_ID \
 --member="serviceAccount:${PROJECT_NUMBER}@cloudbuild.gserviceaccount.com" \
 --role="roles/apikeys.admin"
```

## 8. Resumen

En este codelab, implementaste un marco de trabajo sólido de seguridad de extremo a extremo y automatización para las claves de API de Google Cloud:

1. **Configuraciones predeterminadas reforzadas:** Creaste y restringiste claves de API para limitar el acceso exclusivamente a las APIs necesarias y las plataformas de confianza (como URLs de referencia de HTTP específicas).
2. **Auditaste tu inventario de claves:** Analizaste los entornos de tu proyecto para detectar y aislar las claves sin restricciones que representan un riesgo de seguridad inmediato.
3. **Datos de uso analizados:** Consultaste de forma programática los datos de métricas de Cloud Monitoring para generar perfiles del uso histórico de las claves, lo que te permite restringir las claves según las huellas de uso verificadas.
4. **Mitigación automática de amenazas:** Estableciste un "disyuntor" reactivo conectando una política de alertas de Cloud Monitoring a un tema de Pub/Sub y a un activador de compilación de Cloud Build, lo que te permite borrar automáticamente las claves comprometidas durante los picos anormales de tráfico.

## Próximos pasos

- **Aplica restricciones a todas tus claves de API:** Usa lo que aprendiste en este lab para detectar todas las claves de API parcialmente restringidas o sin restricciones, y aplica restricciones de API y de cliente.
- **Configura un "disyuntor" en las claves de API:** Protege aún más tus claves de API del uso inesperado configurando la eliminación automática de claves en caso de un aumento repentino del consumo. Usa los comandos `gcloud` o Terraform que se muestran en el lab. Considera ajustar los permisos con las [condiciones de IAM](#).
- **Explora las alertas de Monitoring:** Obtén más información para configurar alertas con el [servicio de Google Cloud Monitoring](#).

- **Obtén más información sobre el control de acceso disponible en Google Cloud:** Revisa las [políticas de límite de acceso](#) y la [propagación de cambios de acceso](#).

---

Documento escrapeado y generado automáticamente para Gemini Notebook / Fuente de información.

Origen: <https://codelabs.developers.google.com/api-key-management?hl=es-419#0>